A Review on Airport Cybersecurity: Emerging Threats to Critical Aviation Systems

Suphannee Sivakorn, Sakulchai Saramat, Chanond Duangpayap, Yotsapat Ruangpaisarn, Patsita Sirawongphatsara and Nuttaya Rujiratanapat

Department of Computer Science, Faculty of Science and Technology,
Rajamangala University of Technology Tawan-ok

Email: suphannee_si@rmutto.ac.th, sakulchai_sa@rmutto.ac.th, chanond_du@rmutto.ac.th, yotsapat_ru@rmutto.ac.th, patsita_si@rmutto.ac.th and nuttaya_ru@rmutto.ac.th

Abstract

The aviation industry is one of the critical industries that is not only vulnerable to physical threats, but also cybersecurity threats. Recently, several major airports were hit with coordinated cybersecurity attacks by a group of hackers. The attacks have raised concerns about airport security. In response to these attacks, the aviation enforcement authority and other national aviation agencies plan to add cybersecurity requirements, including the development of cyber incident response plans and cybersecurity assessments, for all airports and airline operators in order to identify and address potential vulnerabilities. The purpose of this paper is to identify recent cybersecurity threats and risks, and provide effective guidelines for improving cybersecurity resilience and best practices in the airport industry. To do this, we review and categorize emerging cybersecurity attacks and threats in the aviation system and recent real-world aviation system security incidents according to the Initial Access Techniques from the MITRE ATT&ACK Framework. Based on this foundation, we analyze and propose the use of modern cybersecurity defense models and practices, such as Cybersecurity Frameworks and Zero Trust Architecture, to strengthen the security posture of the aviation industry.

Keywords: *airport cybersecurity; aviation cybersecurity; airport security; smart airport; critical infrastructure security*

1. Introduction

In the physical world, airport security might involve inspecting airline passengers, baggage, air cargo, and reinforcing secure areas of the airport. Any unlawful interference in the aviation system could pose a threat to life and property, so airport enforcement authorities or other national airport agencies go to great lengths to prevent threats and potentially dangerous situations from arising, as well as ensure their physical security practices align with current security requirements and procedures. In the realm of technology, cybersecurity is however often ignored or given less priority compared to general airport security. This is indicated by a survey conducted in 2018 of the top 200 busiest

commercial airports in Europe and the United States, in which only 59% of respondents stated having an effective cybersecurity policy (Lykou et al., 2019).

Emerging Cybersecurity Threats to Aviation Industry. A pressure to improve cybersecurity for critical aviation systems has grown. There have been a number of reported cybersecurity incidents at airports in recent years. A recent study from Eurocontrol, 2021 showed that cyber attacks are up across the aviation industry, with over 530% year-on-year rise from 2019 to 2022. Here we present a few example recent incidents which affected their operations or their public image.

Killnet. Recently several major U.S. airports were hit with coordinated denial of service (DoS) attacks by a group of hackers identified themselves as Killnet (The Associated Press, 2022). Killnet flood the targeted airport websites with junk data which overloaded the airport servers. Number of the targeted airport websites were inaccessible for several hours (WTW, 2022). Although the attacks had reported no disruption on airport operations nor access to the sensitive information, the attacks have raised concerns on U.S. airport security.

Ransomware attack have significantly increased in the aviation industry. In 2018, Bristol Airport and Hong Kong International Airport suffered widespread ransomware attacks that caused all airport information screens to go offline (Guide & Jones, 2018; Truta, 2018). In 2019, ransomware incidents were reported at major airports in the US, resulting in the disruption of operations at the affected airports, including the cancellation of flights and the disruption of passenger processing (Panettieri, 2019). Other major incidents include Boryspil Ukraine International Airport in 2017 (Burns, 2017) and an attack in Vienna airport's servers (The Local Austria, 2017).

Such attacks have recently received major publicity which were resulted in the theft of sensitive data and, in some cases, they potentially expose citizens to life-threatening risks causing the aviation operations had to be halted. It is important for airports and aviation companies to be proactive in protecting against cybersecurity threats and to have modern defense systems as well as incident response plans in place to enable them to effectively respond to and recover from any incidents that may occur.

Airport Cybersecurity Requirements. The Transportation Security Administration (TSA), an agency of the United States Department of Homeland Security that has authority over the security of transportation systems of the United States, plans to add additional performance-based cybersecurity requirements to require airport and airline (Business Insurance, 2022). Additionally, the International Air Transport Association (IATA) recently plans to add cybersecurity to the aviation security threats that must be subjected to risk assessment and mitigation in the IOSA Standards Manual (ISM) 14th Edition (IATA, 2021). To this end, airports must take steps to protect themselves from cyber threats – identify threats and vulnerabilities of their system and ensure that cybersecurity best practices are applied.

In an effort to help strengthen the security posture of the aviation industry, we identify recent cybersecurity threats and risks. We discuss the airport technology and their security concerns (Section 2). We review and categorize state of cybersecurity threats and the impact of their vulnerabilities using

a combination of literature research and online resources according to the MITRE ATT&ACK Framework (Section 3 and 4). We then analyze and discuss modern cybersecurity defense strategies, architectures and best practices, such as the Cybersecurity Framework and Zero Trust Architecture in the context of defending aviation assets as a recommendation to improve cybersecurity resilience (Section 5).

2. Airport Technology and Security Concerns

Airport Technology Airport operations have evolved dramatically to support the skyrocketing of the global aviation business. This has called for airport technology to increase efficiency in while delivering higher service levels. The evolution of airport technology can be categorized in three stages, namely, Airport 1.0, Airport 2.0 and Airport 3.0 (Koroniotis et al., 2020).

Airport 1.0 mainly focuses on ensuring the safety of aircraft operations such as takeoff, landing, traffic controls. There is low to none security concerns on this first stage of the airport technology (Koroniotis et al., 2020).

Airport 2.0 adapts and enables technologies to enhance collaborations and communications such as IP telephony, broadband, and Wi-Fi (Fattah et al., 2009). Following the United States 9/11 incident, the Transportation Security Administration (TSA) was established in 2001 by the Aviation and Transportation Security Act (ATSA), which their main objective is to oversee security and protect all modes of transportations (TSA, 2021). Due to this reason, there were raise of public safety measurements such as video surveillance and other necessary of physical security measurements.

Airport 3.0 or "Smart Airport" integrates Internet of things, hi-speed communications and other smart sensors to enhance passenger experience. These smart airports often passengers to access to their real-time (or near real-time) information about traffics, flights as well as the airport public internet access, applications and services. Airport IoT devices and smart sensors are deployed throughout the airport facilities. The airport authorized personnel can manage these devices and sensor simultaneously through the airport network systems. Cybersecurity on smart airports has been a subject of interest in recent years as shown in numerous research and studies (Koroniotis et al., 2020; Lykou et al., 2019; Lykou et al., 2018; Gopalakrishnan et al., 2013).

Bring-Your-Own-Device (BYOD). Passengers are able to use their own devices to connect to the airport access points e.g., Public Wi-Fi and charging stations. It is almost inevitable that these personal devices are less secured and more likely to infected with malware. These devices therefore should be treated as untrusted and connected to a segregated network segmentation. The section, Airport Infrastructure Security Risk explores this cybersecurity risks in more details.

3. Airport Cyber Attack Threats

There have been numerous incidents involving air terrorism which target airport and aircraft operations. Over the years, adversary continue to adapt and evolve their tactics and techniques as well as expand their attack landscape, from physical and cyber domains (TSA, 2021). This section

describes different types of cyber-attack threats and their motivations, all of which can potentially impact airport security and disrupt airport operations.

Advanced Persistent Threat (APT). This type of adversary are well organized **hacker group or foreign governments**. Such attackers' motivations are typically political or economic and recently target critical infrastructure entities such as pipeline system (Turton & Mehrotra, 2021), government entities (Lyngaas, 2022), hospitals (O'Donnell, 2019), transportation infrastructures (Mandiant, 2022), including major airports (The Associated Press, 2022). Airports are highly targeted due to their impact on confidence of national aviation safety (Lykou et al., 2019).

Cybercrime. Attackers in this category target systems for valuable and sensitive information. This includes information from other passengers, users in the same Wi-Fi network as well as airport employees and personnel that are connected. Any services that are internet-facing or accessible publicly are targeted. Examples includes stealing sensitive and financial information from public network, installing malware or ransomware to other devices, exploiting vulnerability airport internet-facing services and applications.

Peer Group Service Disruption. Peer groups are individuals or groups of hackers who carry out malicious activity that causes service disruptions to promote political agendas or other believes. Peer group service disruption are not like cybercriminals who break into computer systems to steal data. They are individuals or groups of hackers who work together and see themselves as fighting injustice.

Insider Threats. The insider threat is a threat to an organization that comes from within. These type of threats are usually occurred from current member of the organization or former members, mainly employee and former employee. However, it may also arise from third parties, including contractors and temporary workers. The attack caused by this type of threat often stem from misuse of authorization (Lykou et al., 2019).

4. Airport Cybersecurity Risks

In this section we describe and analyze recent cybersecurity risks and attacks. While cybersecurity attacks on the smart airport, particularly the IoT devices have been extensively explored (Koroniotis et al., 2020; Lykou et al., 2019), limited attention has been given to various cybersecurity entry vectors that are able to gain initial foothold within an airport system, which we categorize into six cybersecurity risks: (1) public-facing access, (2) insecure network architecture (3) untrusted devices (4) internet-facing applications and services (5) social engineering attacks and (6) insider threats.

4.1 Public-facing Access

The following section explores security risks which are imposed by allowing passengers to access aviation system public facing services.

Bring Your Own Device (BYOD). Allow BYOD in the enterprise environment has been a concern for exposing organization to security vulnerabilities (Trend Micro, 2015; Brook, 2022). People commonly use their own devices in aviation system as part of their flying experience. The BYOD in this setting is different from enterprise workplace BYOD due to the varieties of the connected devices. Mobile Device Management (MDM) (Bridgwater, 2014), one of the common practices to monitor and manage devices, is unusable in this case. This increases a risk of introducing any malware or malicious activities to the network when connected.

Public Wi-Fi Access. Public Wi-Fi Access is nearly everywhere – airports, coffee shops, libraries and hotels. As described most smart airports provide internet access as it considered to be necessary and vulnerable service to their passengers (Fattah et al., 2009). However, it is commonly known by security experts that the public Wi-Fi can leave users vulnerable to cyberattacks as shown in many studies and research e.g., Joshi et al., 2009; Marlinspike, 2009; Stouffer, 2022. This public Wi-Fi poses a higher risk when the airport does not isolate their network segmentation properly (See Section 4.2 for more details). The attacker is able to utilize the network access to direct their attacks to other systems. The common Wi-Fi security risks can be categorized as follows.

Man-in-the-middle (MITM) attack is the most common risk of the public Wi-Fi access. MITM comes in the form of eavesdropping where cybercriminals use snooping and sniffing tools (e.g., XXX) to perform their attacks including stealing sensitive information and hijack your login session as shown in number of studies. Several studies have demonstrated how easily attackers to hijack user's session and information when there is no encryption. (Marlinspike, 2009; Englehardt et al., 2015; Zheng et al., 2015, Sivakorn et al., 2016). Nevertheless, many critical websites continue to serve content over unencrypted connections or not enforcing encryption (Sivakorn et al., 2016; Sivakorn et al., 2020; Sivakorn et al., 2022).

Malware from Untrusted Devices. In this attack bad actor can inject malware onto Wi-Fi users. Attackers can attempt to intercepting and modify data coming into the victim. Specifically, attackers can modify and inject malicious code, phishing and malicious links and payloads. This technique is well known by hacker community (Kacic et al., 2013; Zimba et al., 2019) and highly successful when there is no encryption over the traffic. In addition, the adversary can exploit user device's vulnerabilities to inject malware and compromise the device. Such attack is prevalent in popular devices e.g., iOS devices (Spaulding et al., 2012) and using tools like Metasploit[1] to exploit device vulnerabilities.

Malicious Hotspots. Malicious hotspot is another type of attacks to the public Wi-Fi (also known as "rogue access point"). The attack has been around since the birth of the Wi-Fi technology. The attacker first set up a wireless access point with an identical SSID name to lure users to join. Their fake access point might have a stronger signal than the real Wi-Fi access point. The

[1] Rapid7 Metaspoloit - https://www.metasploit.com/

unsuspecting users may join the rogue attacker-controlled network and later be a victim of man-in-the-middle (Roth et al., 2008; Kaspersky, 2021) or other network related attack as described above.

4.2 Insecure Network Architecture

Insecure network architecture allows attackers to gain access to internal system and laterally move to different assets of the organization – that is no control and isolation within the organization's network. **Network segmentation** is a network security architecture that divides a network into multiple segments. Each network segmentation functions as an individual network. Segmentation works by controlling the flow of traffic within the network. Network administrators therefore have more control over network traffic. This helps improving overall network security posture, as the traffic can be restricted or allowed to a particular segment based on security policies – each of which can have varying security policy and hold specific application with different trust levels (Palo Alto Network, 2022).

As there is a plethora of valuable assets at the airport that need to be secured properly, each asset belongs to different entities and stakeholders. A basic example of these can be described as follows.

(1) Public Wi-Fi is an internet-accessible network that allows passengers at the airport to connect and access internet services as described in Section 4.1.

(2) IoT Devices or Internet of Things devices are devices that are embedded with sensors, software, and other technologies for the purpose of connecting and exchanging data with other devices and systems over the internet. Examples of IoT devices include sensors capture data about physical environment and functions to help airport operations e.g., temperature sensors and controls, lighting controls, security camera, fire safety and luggage handling (Koroniotis et al., 2020). The IoT devices have been widely adopted in the aviation industry as shown in the result of the survey by Mariani et al., 2021.

(3) Airport Back Office is responsible for administration, operations and logistics of the airport which includes multiple departments, for example, airport operations, airport traffic control, airport engineering, passenger assistance. Together these departments work in synergy so that the airport can operate efficiently.

(4) Critical Infrastructure is a set of important assets that are essential for the airport to work and operate correctly. Example of these are Air Traffic Management (ATM), and Automatic Dependent Surveillance-Broadcast (ADS-B) (Lykou et al., 2019).

4.3 Untrusted Devices

We have described the risk of allowing access of untrusted devices in the previous (Section 4.1). Nevertheless, the public Wi-Fi access of an airport is crucial for the passengers, not only as a convenience for the passenger, but also as a vital tool for communicating with travelers. The public Wi-Fi thus must consider to be an untrusted or unsafe network and should be entirely separated from the other airport networks to avoid any malicious activities that can spread to other airport entities and assets e.g., network attack to CCTV systems (Lykou et al., 2019) and malware on airport network at Vienna Airport (The Local Austria, 2017).

Figure 1 shows a basic example of network segmentation that can be applied to an airport. The public Wi-Fi network is segmented separately. Without the network segmentation, the attacker can perform their attack directly against airport critical infrastructures and disrupt the airport operations by connecting to the public network provided.

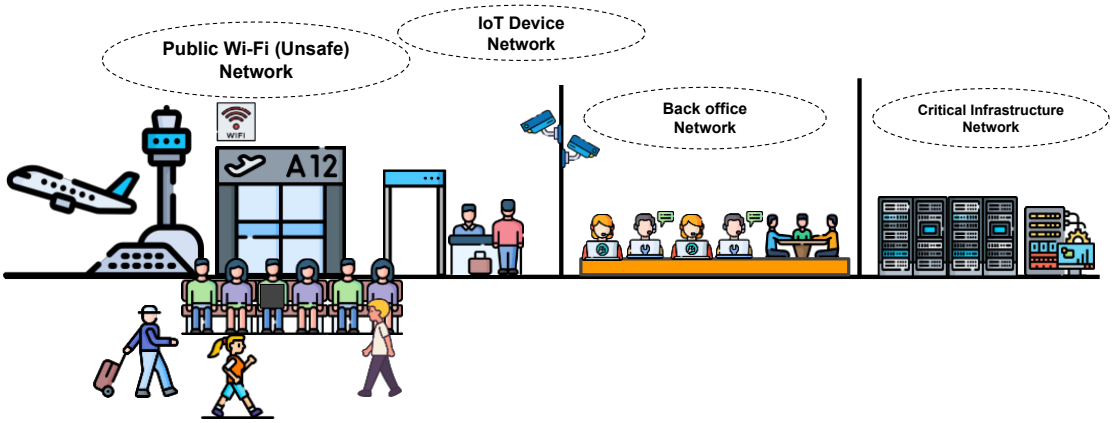

Figure 1: Example of network segmentations in an airport

Unsafe Internet of Things (IoT) and Smart Devices. The integration of IoT devices has tremendously changed the traditional airport to be more automated operation. Here we analyze the attack surface and risks from deploying IoT and smart devices in the aviation system.

Security Vulnerability. Security vulnerability is a weakness, flaw or error found in systems, in this case, IoT devices, which allows an attacker to create an exploitation to gain unauthorized access to them, which can be caused by known or unknown software and hardware bugs and misconfigurations. Examples of recent major exploited vulnerabilities include Log4Shell[2], ProxyLogon[3] (CISA, 2022). Some of the vulnerabilities are zero-day vulnerabilities – vulnerabilities that their attack has been happened before a developer has created a patch to fix. The growing concern around IoT security vulnerability includes the fact that threat actors can damage the IoT devices themselves as well as other assets in the same network as demonstrated in the numerous attacks in the wild e.g., the Mirai IoT botnet attack (Shea, 2020).

Lack of a security update mechanism. IoT devices are also subjected to these vulnerabilities, as they also rely on software and hardware dependencies. These devices often lack of a security update mechanism and leave them continue to vulnerable to the attack even if the patch has been publicly released (Keyfactor, 2020).

No common standards and specifications. Currently there is no commonly accepted standard for developing an IoT device. The implementation and design choices of the IoT devices are

[2] https://nvd.nist.gov/vuln/detail/CVE-2021-44228

[3] https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-26855

up to the developer and subject to be different (Koroniotis et al., 2020). This lack of standards and specifications affects majorly in the security aspect, as it requires user to maintain various technologies to support these devices properly.

Supply Chain Compromise. Supply chain compromise is an attack technique which the attacker aims to manipulate the product (hardware and/or software) before receipt by the consumer. By compromising a single supplier, bad actors can hijack its distribution systems. For example, compromised chips or drivers (Robertson, 2018) that run in the IoT and smart devices, which later deployed in the airport. Supply chain attack such as SolarWinds hack was demonstrated on a massive scale, allowing access to over 18,000 networks around the world (Greenberg, 2021).

Lack of Physical Hardening. Because of the nature of IoT application, devices are usually deployed in different places around the airport and sometimes are not kept in a secure location but exposed to perform their tasks. When operating unattended, these IoT devices might be tampered with by physical access. These devices can be stolen, opened and later access the inner circuits and ports.

4.4 Internet-facing Applications and Services

Adversaries often attempt to take advantage of any weakness in an internet facing application which can be caused by e.g., software bugs, design flaws, unpatched vulnerabilities as described in Section 4.4. Since numerous internet-based services have been prevalently provided by smart airports, these services become vulnerable to this type of attack.

Network Denial of Service Attacks. The denial of service (DoS) attack impacts the availability of the smart airport services as it renders the service unavailable for a period of time e.g., DoS airport website attacks (Business Insurance, 2022), Polish Airline DDoS incident (The Guardian, 2015). There has been a significant increase in cyber criminals demanding ransom payments to stop their DoS attack of online services (Palmer, 2022) in multiple industries because cryptocurrencies allow cyber criminals to receipt money with anonymity.

4.5 Social Engineering Attacks

Social engineering attacks focus on human element of a system which adversaries attempt to trick or lure users of the system for the purpose of information gathering, fraud or a system access. All aviation personnel are vulnerable to this type of attacks.

Phishing. Phishing attack targets an employee or an authorized personnel that has privileges access to system. Phishing typically is carried out by email spoofing, and other social networking which often direct the victim to enter sensitive information at phishing websites or download malicious payloads, typically to execute malicious code on victim systems.

Malware and Ransomware. Phishing is one of the mechanism that adversaries can deliver malware and ransomware to the victim computer or system. The vast majority of organizations have been targeted by phishing or ransomware which includes aviation systems. Bristol International Airport in England was recently a victim of this type of attack. Their flight information screen system was infected by ransomware and failed to operate properly (Guide & Jones, 2018).

4.6 Insider Threat

Insider threat is one of a security risk that causes by a person who has access to sensitive information or privileged accounts misuses or abuses their authorization. Insider threats could be presented in the Figure 1 as employees working in the aviation system back office network. A malicious insider (also known as Turncloak) is someone who intentionally abuses legitimate access to steal sensitive information or seeks to manipulate or sabotage a critical aviation system. Turncloaks have an advantage over other type of attackers as they are familiar with the system, loopholes, vulnerabilities and the organization's security policy.

4.7 Airport Security Risks and MITRE ATT&CK Framework

Section 4.1 – 4.6 of this paper analyzed and described the most common types of the airport security risks. To this end, we categorized and mapped these risks according to the MITRE ATT&CK Framework (MITRE, 2022), which is widely adopted cybersecurity framework used by organization worldwide to analyze threats and improve security defenses. A summary of airport security risks categorized is provided in Table 1. The columns provide all nine initial access[4], which are commonly used to gain a foothold in a system. Each technique is assigned an ID (e.g., T1189, T1190), along with its name, description, examples and mitigations. We hope that this will help guide readers to further explore each risk with the practical tactics and industry-standard mitigations provided by the MITRE ATT&CK. Some airport security risks can be categorized into more than one MITRE ATT&CK initial access techniques due to their related technical details.

Table 1: Summary of the Airport Security Risks categorized according to the MITRE ATT&CK Matrix for Enterprise Initial Access Techniques

Airport Security Risks	**MITRE ATT&CK Matrix for Enterprise Initial Access Techniques (TA0001)**								
	T1189	**T1190**	**T1133**	**T1200**	**T1566**	**T1091**	**T1195**	**T1199**	**T1078**
1. Public-facing Access		X	X	X					
2. Insecure Network Architecture		X	X						
3. Untrusted Devices			X	X		X	X		
4. Internet-facing Applications and Services		X	X						
5. Social Engineering Attacks	X				X				X
6. Insider Threat						X		X	

The sign 'X' indicates that the airport security risk shown can be categorized according to the specific MITRE ATT&CK technique(s).

T1189	Drive-by Compromise
T1190	Exploit Public-Facing Application
T1133	External Remote Services

[4] https://attack.mitre.org/tactics/TA0001/

T1200	Hardware Additions
T1566	Phishing
T1091	Replication Through Removable Media
T1195	Supply Chain Compromised
T1199	Trusted Relationship
T1078	Valid Accounts

5. Airport Modern Defense Techniques

Here, we provide the airport modern defense techniques and best practices, such as the Cybersecurity Framework and Zero Trust Architecture in the context of defending aviation assets as a recommendation to improve cybersecurity resilience.

5.1 Cybersecurity Frameworks

An effective cybersecurity governance requires the aviation boards and senior management to have a clear understanding of the cybersecurity vulnerabilities and the significance of their cybersecurity programme. The organization needs to know how to establish an information security programme, how to evaluate their own risk, and how to design an effective strategy and objectives of a security programme. Use of a framework, such as the ISO 27000 series[5] or the National Institute of Standards and Technology's (NIST) Cybersecurity framework[6], may help to identify the organization's areas of weakness and enable objectives to be created. Furthermore, the frameworks provide organizations standards, guidelines and best practices to improve security and resilience through understanding, managing, and reducing the organization's cybersecurity risk. The Civil Air Navigation Services Organization (CANSO) proposed a guide for increasing security level to aviation systems through the use of cybersecurity frameworks (CANSO, 2020). A number of airports around the world has already adopted the cybersecurity framework in their operation including the Airports of Thailand (AOT, 2021).

Airport Cybersecurity Policy. By definition, cybersecurity policy refers to well-defined and comprehensive plans, rules, and practices that are designed to protect the company's assets. The policy might also include an explanation of organization's security measurements and enforcements, as well as a procedure for evaluating the effectiveness of the policy. Cybersecurity policies are also critical to the public image and credibility of an organization as it serves as a public statement about the organization's commitment to cybersecurity (Szuba, 1998). Examples of this public statement is the AOT cybersecurity policy[7].

Security Awareness Training. Airport personnel are part of an airport's attack surface. In fact, a study by IBM in 2021 reported that 95% of all cybersecurity issues can be traced back to

[5] https://www.iso.org/standard/73906.html

[6] https://www.nist.gov/cyberframework

[7] https://corporate.airportthai.co.th/storage/2021/08/AOT-Cyber-Security-Policy.pdf

human error (The Hacker News, 2021). Such a study highlights the potential severity of human error, and the importance of people to defense the organization. Furthermore, to meet regulatory requirements in the near future, the aviation system might be required to provide security awareness training to employees (TSA, 2021; IATA, 2021). An organization should understand what goes into building a security awareness training program, get involved, and offer feedback throughout the process.

5.2 Zero Trust Architecture

Zero Trust is a modern essential cybersecurity architecture that embraces the concept of verifying and securing every entity, enforcing principle of least privilege – all entities must be given only those privileges needed to complete their task, along with capturing and analyzing logs and telemetries for real-time response to threats. Traditional security architecture operates on an assumption that everything inside the organization should be implicitly trusted, however in reality any internal-access bad actors – e.g., untrusted devices and personnel are free to move laterally to access different internal assets including critical asset and sensitive information due to lack of granular security controls. Next we explain how airport security can benefit from the Zero Trust architecture.

Visibility for Subsystems. The first step in integrated Zero Trust architecture is the identification of organization assets, understanding their valuable, their stakeholders and their connectivity. This helps to prioritize where to enable Zero Trust Security policies i.e., securing access entry, enforcing least privilege and enhancing visibility to these subsystems. For example, enabling critical infrastructure logging i.e., ATM and IoT device access and operational logs. Additionally, not only will aviation systems have to bring all of these devices within their network perimeter, but they must also plan for how to manage them e.g., security policies, diagnostics, updates, user authentication. For example, monitoring IoT and smart devices through *IoT device management* to handle the IoT lifecycle: onboarding, configuration, diagnostics and troubleshoots, updates, maintenance and end of life.

Network Segmentation. As mentioned in the Section 4.2, network segmentation is one of the fundamental of Zero Trust architecture as it allows the network administrator to enforce least privileges security policy. As mentioned, Figure 1 shows an example of airport network segmentation where each network segments are separated by different stakeholders and restrict the access to only necessary stakeholders e.g., IoT device network are segregated from other network segments which allows only IoT administrators to access the network – avoids other unauthorized party to discover and exploit IoT vulnerabilities if any as well as avoids any lateral movement to different parts of the airport infrastructure.

Demilitarized zone (DMZ). Internet-based services and applications are often targeted as they are accessible from the internet and users which includes malicious actors. Exploiting public-facing application is one of the most popular initial access techniques listed in The MITRE ATT&CK Framework. It is a good practice to configure a separate network segment for any internet-facing hosts. Because of the potential of these hosts suffering a cyber-attack, they are placed into this specific

subnetwork in order to protect the rest of the network in case that any of them become compromised. In cybersecurity, this internet-facing segment is called “Demilitarized Zone” (or DMZ). As depicted in Figure 2, DMZ is a network segment between internal network zone and the internet. DMZ acts as a gateway from the public Internet and has various special network restrictions e.g., DMZ have only limited connectivity to specific hosts in the internal network, hosts in the DMZ are restricted to serve only desired protocols which are controlled by strict network policies e.g., application firewalls, packet filter firewalls.

The outer firewall in Figure 2 controls and filters the internet traffic from any malicious activities. The inner firewall in Figure 2 controls and intervenes the traffic between DMZ servers and the internal network. This configuration provides additional security from external attacks to access other critical infrastructures of the airport e.g., the airport web servers are placed in the DMZ while the airport database servers containing sensitive information are placed internally behind the two firewalls, the inner and outer firewalls. Any other airport services that is being provided to external users on the internet can be placed in the DMZ.

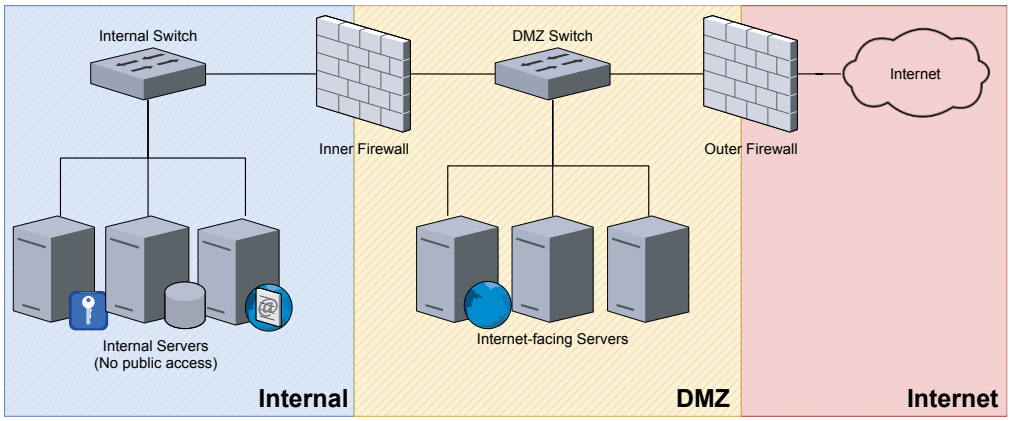

Figure 2: DMZ subnet that separates an enterprise internal network from other untrusted networks e.g., the Internet.

5.3 Internet of Things and Smart Device Management

As described in Section 4.3, the augmentation of IoT and smart devices increased the complexity of cybersecurity attacks. In this section, we proposed various techniques that can help to secure the use of IoT devices in the airport.

Third Party Due Diligence. Due diligence is one of the common process when an organization seeks to outsource or take a new supplier or vendor in order to avoid the incurred risks caused by the third-party. Any IoT devices introduced to the airport system are parts of airport asset and therefore must be protected and considered to be part of the airport threat landscape. By having a proper selection process – e.g., adoptability, security measurements, secure update mechanism,

and supporting systems, before taking any security liability is extremely important to the overall security posture and reduce unforeseen security incidents caused from these devices.

Physical Access Restriction – Tamper Proof. IoT devices often placed around airport area making these devices vulnerable to physical access attacks. Criminal can steal the devices, bring them to their private location to gain access. Some IoT device manufacturers are carelessly leave the default username and password underneath the device case or have no tamper proof mechanism. Several tamper-proof techniques can be applied to the devices (Katz, 2007; Gennaro et al., 2004). For example, these devices can be protected by placed in a secure case or tamper-resistant case at a minimum and disabled or factory reset the device upon tampering.

5.4 Insider Threat Mitigation

Insider threats can be difficult to identify or prevent than other types of attack as they are invisible to traditional security solutions. Nevertheless, the prevent of insider threat lie in applying the principle of least privilege, as the bad actor cannot harm other unauthorized systems. This principle must be done along with other practices i.e., enforcing security policy, as well as visibility to employee actions to monitor any anomalous activities for foul plays e.g., unauthorized access, unusual volume of traffic, or unusual access time. *Zero-trust architecture* could protect against the insider threat as the user has to verify their identity each time that they request to access a new resource, and every access is mediated, logged, and analyzed.

6. Conclusion

In this paper, we explored the importance of airport cybersecurity and emerging airport cybersecurity threats. Based on insights from recent aviation system studies and various real-world cybersecurity attack incidents, we analyzed, summarized and categorized major airport cybersecurity risks according to the Initial Access Techniques from the MITRE ATT&ACK Framework including (1) public-facing access, (2) insecure network architecture (3) untrusted devices (4) internet-facing applications and services (5) social engineering attacks and (6) insider threats. Several of these risks could potentially expose passengers to risks ranging from personal data leakages to life-threatening scenarios. Ultimately, we presented the application of Cybersecurity Frameworks and Zero Trust Architecture, along with other modern security measures such as IoT device and smart device management and insider threat mitigations. We hope that this study will be very useful for the aviation industry in understanding the current threat landscape of aviation systems and enhancing their cybersecurity defense and resilience.

7. References

AOT. (2019). *ความปลอดภัยด้านเทคโนโลยีสารสนเทศและความเป็นส่วนตัว*. Airports of Thailand. Retrieved November 29, 2021, from https://corporate.airportthai.co.th/th/cybersecurity-th/

The Associated Press. (2022, October 10). *Denial-of-service attacks knock US airport websites offline*. AP News. Retrieved November 21, 2022, from https://apnews.com/article/technology-business-atlanta-680cf93f7eb0300127448c35299ad66e

Bridgwater, A. (2014, November 8). *How mobile device management is taking on the BYOD challenge*. Theregister. Retrieved November 23, 2022, from https://www.theregister.com/2014/11/08/mobile_working/

Brook, C. (2022, November 7). *The Ultimate Guide to BYOD Security: Definition & More*. Digital Guardian. Retrieved November 23, 2022, from https://digitalguardian.com/blog/ultimate-guide-byod-security-overcoming-challenges-creating-effective-policies-and-mitigating

Burns, E. (2017, June 27). Chaos in Ukraine as ransomware cyber attack hits airports, banks & government. Tech Monitor. Retrieved November 21, 2022, from https://techmonitor.ai/technology/cybersecurity/chaos-ukraine-ransomware-cyber-attack-hits-airports-banks-government

Business Insurance. (2022, October 12). *US to add cybersecurity requirements for critical aviation systems*. Business Insurance. Retrieved November 21, 2022, from https://www.businessinsurance.com/article/20221012/NEWS06/912353045/US-to-add-cybersecurity-requirements-for-critical-aviation-systems

CANSO. (2020, September). *CANSO Standard of Excellence in Cybersecurity*. Retrieved November 28, 2022, from https://canso.fra1.digitaloceanspaces.com/uploads/2021/04/canso_standard_of_excellence_in_cybersecurity.pdf

CISA. (2022, April 27). *2021 Top Routinely Exploited Vulnerabilities | CISA*. US-CERT. Retrieved November 27, 2022, from https://www.cisa.gov/uscert/ncas/alerts/aa22-117a

Englehardt, S., Reisman, D., Christian, C., Zimmerman, P., Mayer, J., Narayanan, A., & Felten, E. N. (2015, May). Cookies That Give You Away: The Surveillance Implications of Web Tracking. *WWW '15: Proceedings of the 24th International Conference on World Wide Web*.

Eurocontrol (2021, July). *EUROCONTROL Think Paper #12 - Aviation under attack from a wave of cybercrime.* Retrieved November 23, 2022, from https://www.eurocontrol.int/publication/eurocontrol-think-paper-12-aviation-under-attack-wave-cybercrimes

Fattah, A., Lock, H., Buller, W., & Kirby, S. (2009, July). *Smart Airports: Transforming Passenger Experience To Thrive in the New Economy*. Cisco. Retrieved November 22, 2022, from https://www.cisco.com/c/dam/en_us/about/ac79/docs/pov/Passenger_Exp_POV_0720aFINAL.pdf

Gennaro, R., Lysyanskaya, A., Malkin, T., Micali, S., & Rabin, T. (2004). Theory of Cryptography Conference TCC 2004: Theory of Cryptography pp 258–277Cite as Algorithmic Tamper-Proof (ATP) Security: Theoretical Foundations for Security against Hardware Tampering. *Theory of Cryptography Conference*, *2951*, 258-277. 10.1007/978-3-540-24638-1_15

Gonzales, H., Bauer, K., Lindqvist, J., McCoy, D., & Sicker, D. (2010). Practical Defenses for Evil Twin Attacks in 802.11. *2010 IEEE Global Telecommunications Conference (GLOBECOM)*, 1-6. 10.1109/GLOCOM.2010.5684213

Gopalakrishnan, K., Govindarasu, M., Jacobson, D., & Phares, B. M. (2013). CYBER SECURITY FOR AIRPORTS. *International Journal for Traffic and Transport Engineering (IJTTE)*, *3*(4), 365-376.

Greenberg, A. (2021, May 31). *Hacker Lexicon: What Is a Supply Chain Attack?* WIRED. Retrieved November 27, 2022, from https://www.wired.com/story/hacker-lexicon-what-is-a-supply-chain-attack/

The Guardian. (2015, June 21). *Hackers ground 1400 passengers at Warsaw in attack on airline's computers*. The Guardian. Retrieved November 27, 2022, from https://www.theguardian.com/business/2015/jun/21/hackers-1400-passengers-warsaw-lot

Guide, S., & Jones, K. (2018, September 17). *Bristol International Airport vs Ransomware*. Hacker Combat. Retrieved November 27, 2022, from https://hackercombat.com/bristol-international-airport-vs-ransomware/

The Hacker News. (2021, February 4). *Why Human Error is #1 Cyber Security Threat to Businesses in 2021*. The Hacker News. Retrieved November 28, 2022, from https://thehackernews.com/2021/02/why-human-error-is-1-cyber-security.html

IATA. (2021, December). *Compilation of Cyber Security Regulations, Standards, and Guidance Applicable to Civil Aviation Edition 3.0*. https://www.iata.org/contentassets/4c51b00fb25e4b60b38376a4935e278b/compilation-of-cyber-regulations-standards-and-guidance_3.0.pdf

Joshi, Y., Das, D., & Saha, S. (2009, December). Mitigating man in the middle attack over secure sockets layer. *2009 IEEE International Conference on Internet Multimedia Services Architecture and Applications (IMSAA)*.

Kacic, M., Hanacek, P., Henzi, M., & Jurnecka, P. (2013, September). Malware injection in wireless networks. *2013 IEEE 7th International Conference on Intelligent Data Acquisition and Advanced Computing Systems (IDAACS)*. 10.1109/IDAACS.2013.6662732

Kaspersky. (2021). *What is an Evil Twin Attack? Evil Twin Wi-Fi Explained*. Kaspersky. Retrieved November 23, 2022, from https://www.kaspersky.com/resource-center/preemptive-safety/evil-twin-attacks

Katz, J. (2007). Universally Composable Multi-party Computation Using Tamper-Proof Hardware. *Annual International Conference on the Theory and Applications of Cryptographic Techniques*, *4515*, 115-128. 0.1007/978-3-540-72540-4_7

Keyfactor. (2020, October 28). *Top 10 IoT Vulnerabilities in Your Devices*. Keyfactor. Retrieved November 27, 2022, from https://www.keyfactor.com/blog/top-10-iot-vulnerabilities-in-your-devices/#lack-of-physical-hardening-10

Koroniotis, N., Moustafa, N., Schiliro, F., Gauravaram, P., & Janicke, H. (2020). A Holistic Review of Cybersecurity and Reliability Perspectives in Smart Airports. *IEEE Access*, *8*. 10.1109/ACCESS.2020.3036728

The Local Austria. (2017, February 28). *Turkish suspect identified in Vienna airport cyber attack*. The Local Austria. Retrieved November 27, 2022, from https://www.thelocal.at/20170228/suspect-identified-in-vienna-airport-cyber-attack/

Lykou, G., Anagnostopoulou, A., & Gritzalis, D. (2018). Implementing Cyber-Security Measures in Airports to Improve Cyber-Resilience. *2018 Global Internet of Things Summit (GIoTS)*, 1-6. 10.1109/GIOTS.2018.8534523

Lykou, G., Anagnostopoulou, A., & Gritzalis, D. (2019). Smart Airport Cybersecurity: Threat Mitigation and Cyber Resilience Controls. *Sensors*, *19*(1), 19. https://doi.org/10.3390/s19010019

Lyngaas, S. (2022, May 26). *Ransomware attack hits New Jersey county, Ransomware attack disrupts New Jersey county*. CNN. Retrieved November 22, 2022, from https://edition.cnn.com/2022/05/26/politics/new-jersey-somerset-county-ransomware-attack/index.html

Mandiant. (2022). *Advanced Persistent Threats (APTs) | Threat Actors & Groups*. Mandiant. Retrieved November 23, 2022, from https://www.mandiant.com/resources/insights/apt-groups

Mariani, J., Zmud, J., Krimmel, E., Sen, R., & Miller, M. (2021). *Flying smarter: The smart airport and the Internet of Things*. Deloitte Insight. https://www2.deloitte.com/us/en/insights/industry/public-sector/iot-in-smart-airports.html

Marlinspike, M. (2009). *New Tricks For Defeating SSL In Practice*. Black Hat USA.

MITRE (2022). *MITRE ATT&CK Matrix for Enterprise.* Retrieved November 27, 2022, from https://attack.mitre.org/

O'Donnell, L. (2019, December 16). *N.J.'s Largest Hospital System Pays Up in Ransomware Attack*. Threatpost. Retrieved November 22, 2022, from https://threatpost.com/ransomware-attack-new-jersey-largest-hospital-system/151148/

Palmer, D. (2022, January 11). *DDoS attacks that come combined with extortion demands are on the rise*. ZDNET. Retrieved November 27, 2022, from https://www.zdnet.com/article/ddos-attacks-that-come-combined-with-extortion-demands-are-on-the-rise/

Palo Alto Network. (2022). *What Is Network Segmentation?* Palo Alto Networks. Retrieved November 25, 2022, from https://www.paloaltonetworks.com/cyberpedia/what-is-network-segmentation

Panettieri, J. (2019). *Ransomware Attack List: Cities, Municipalities and Government Agencies.* MSSP Alert. Retrieved November 25, 2022, from https://www.msspalert.com/cybersecurity-breaches-and-attacks/ransomware/attack-list-cities-government-agencies/

Purpura, P. (2013). *Security and Loss Prevention: An Introduction* (6th ed.). Elsevier Science. https://doi.org/10.1016/C2010-0-69612-X

Robertson, J. (2018, October 4). *China Used a Tiny Chip in a Hack That Infiltrated U.S. Companies*. Bloomberg.com. Retrieved November 27, 2022, from https://www.bloomberg.com/news/features/2018-10-04/the-big-hack-how-china-used-a-tiny-chip-to-infiltrate-america-s-top-companies

Roth, V., Polak, W., Rieffel, E., & Turner, T. (2008, March). Simple and effective defense against evil twin access points. *Proceedings of the first ACM conference on Wireless network security*, 220-235. https://doi.org/10.1145/1352533.1352569

Shea, S. (2020, February). *The Mirai IoT botnet holds strong in 2020*. TechTarget. Retrieved November 27, 2022, from https://www.techtarget.com/searchsecurity/feature/The-Mirai-IoT-botnet-holds-strong-in-2020

Sivakorn, S., Iasonas, I., & Keromytis, A. D. (2016, May). The Cracked Cookie Jar: HTTP Cookie Hijacking and the Exposure of Private Information. *2016 IEEE Symposium on Security and Privacy (S&P)*, 724-742.

Sivakorn, S., Keromytis, A. D., & Polakis, J. (2016, October). That's the way the Cookie crumbles: Evaluating HTTPS enforcing mechanisms. *Proceedings of the 2016 ACM on Workshop on Privacy in the Electronic Society*, 71-81.

Sivakorn, S., Rujiratanapat, N., Sirawongphatsara, P., Sakulchai, S., Ruangpaisarn, Y., & Duangpayap, C. (2022, June 30). An Empirical Study of the Internet Banking Web Encryption in Thailand. *Rajamangala University of Technology Tawan-ok Research Journal*, *15*(1), 97-116.

Sivakorn, S., Sirawongphatsara, P., & Rujiratanapat, N. (2020, November). Web Encryption Analysis of Internet Banking Websites in Thailand. *17th International Joint Conference on Computer Science and Software Engineering (JCSSE)*, 139-144.

Spaulding, J., Krauss, A., & Srinivasan, S. (2012). Exploring an open WiFi detection vulnerability as a malware attack vector on iOS devices. *2012 7th International Conference on Malicious and Unwanted Software*, 87-93. 10.1109/MALWARE.2012.6461013

Stouffer, C. (2022, September 15). *Public Wi-Fi: An ultimate guide on the risks + how to stay safe*. Norton. Retrieved November 28, 2022, from https://us.norton.com/blog/privacy/public-wifi

Szary, W., & Auchard, E. (2015, June 22). *Polish airline, hit by cyber attack, says all carriers are at risk*. Reuters. Retrieved November 27, 2022, from https://www.reuters.com/article/us-poland-lot-cybercrime-idUKKBN0P21DC20150622

Szuba, T. (1998). *Safeguarding Your Technology: Practical Guidelines for Electronic Education Information Security*. National Center for Education Statistics.

Trend Micro. (2015, May 29). *The Case for Making BYOD Safe - Security News*. Trend Micro. Retrieved November 23, 2022, from https://www.trendmicro.com/vinfo/us/security/news/internet-of-things/the-case-for-making-byod-safe

Truta, F. (2018). *Hong Kong airline hacked, 9.4 million customers affected.* Security Boulevard. Retrieved November 22, 2022, from https://securityboulevard.com/2018/10/hong-kong-airline-hacked-9-4-million-customers-affected/amp/

TSA. (2021, September 29). *20 Years After 9/11: The State of the Transportation Security Administration | Transportation Security Administration*. TSA. Retrieved November 22, 2022, from https://www.tsa.gov/news/press/testimony/2021/09/29/20-years-after-911-state-transportation-security-administration

Turton, W., & Mehrotra, K. (2021, June 4). *Colonial Pipeline Cyber Attack: Hackers Used Compromised Password*. Bloomberg.com. Retrieved November 22, 2022, from https://www.bloomberg.com/news/articles/2021-06-04/hackers-breached-colonial-pipeline-using-compromised-password

WTW. (2022, October 28). *Client alert: Recent airport denial-of-service attacks*. https://www.wtwco.com/en-US/Insights/2022/10/client-alert-recent-airport-denial-of-service-attacks

Zheng, X., Jiang, J., Liang, J., Duan, H., Chen, S., Wan, T., & Weaven, N. (2015). Cookies Lack Integrity: Real-World Implications. *24th USENIX Security Symposium (USENIX Security 15)*, 707-721.

Zimba, A., Wang, Z., & Mulenga, M. (2019). Cryptojacking injection: A paradigm shift to cryptocurrency-based web-centric internet attacks. *Journal of Organizational Computing and Electronic Commerce*, *29*(1), 40-59. 10.1080/10919392.2019.1552747